SKITII INTERNAL COMPLIANCE REVIEW

EU GDPR Compliance Review

Engineering assessment of Skitii Product Frontend, Admin Frontend, Backend, Database, and AWS infrastructure for EU GDPR readiness.

NOT EU GDPR COMPLIANT TODAY

Author: Swapnil Sagvekar

Audience: Product, engineering, legal

Scope: Frontend · Backend · Database · Servers

Published: 15 July 2026

Review date: 15 July 2026 **Focus:** EU GDPR readiness

Systems: Product + Admin + API + MongoDB + AWS

Skitii — EU GDPR Compliance Review

Date: 15 July 2026
Scope: Product Frontend, Admin Frontend, Backend, Database, Servers (AWS)
Focus: EU GDPR readiness

1. Summary

Skitii has **good technical security** in place (HTTPS, secrets management, role-based access, encrypted file storage).

However, the product is **not currently GDPR-ready for the EU**, mainly because:

1. We store **patient identity + health (HRV/session) data** — this is sensitive under GDPR.
2. We do **not** yet support core GDPR user rights (erase data, export data, clear retention).
3. We do **not** have required legal/product notices (privacy policy, consent).
4. Systems run in **India (AWS Mumbai)**, not in the EU — an issue for European data.

Conclusion: Skitii should **not** be described as EU GDPR compliant today. Further product, legal, and infrastructure work is required before EU go-live or EU compliance claims.

2. Why this matters

Skitii processes:

Data type	Examples
Personal data	**Patient name, age, gender, registration number; user email**
Health-related data	**HRV / session readings, wellbeing score**
Operational data	**Analytics events, email logs**

Under EU GDPR, health-related data is **special category data** and requires stronger controls, clear legal basis, and respect for user rights.

3. Findings by layer

3.1 Frontend (Product + Admin)

Item	Status	Notes
Privacy policy / notice in app	Missing	Users are not informed how data is used
Cookie / tracking notice	Missing	No consent/notice flow found
Consent for health data collection	Missing	No clear consent capture before processing
Delete-my-data / erase flow	Missing	Not available in UI
Export-my-data flow	Missing	Not available in UI
Patient create / update / session use	Present	Product can collect and use patient/session data

Frontend verdict: **Not GDPR-ready for EU (notices, consent, and data-subject rights UI missing).**

3.2 Backend (API)

Item	Status	Notes
Create / update / list patients	Present	Normal product capability
Store sessions + HRV readings	Present	Sensitive health data stored
Delete / erase patient + related data	Missing	No patient erase API found
Export patient / user data	Missing	No portability API found
Data retention for patients / sessions	Missing	No auto-delete / retention policy in system
Email log retention	Partial	Email logs TTL (~30 days) exists
Access control by role	Present	Institution / admin roles enforced
Security basics (Helmet, validation, CORS, secrets)	Present	Good baseline

Backend verdict: **Can store sensitive data, but lacks GDPR rights APIs (erase / export / retention).**

3.3 Database

Item	Status	Notes
MongoDB stores personal + health data	Yes	Patients, sessions, readings, users, analytics
Session records keep patient fields	Yes	Name / age / gender copied into sessions
Full erase across all collections	Not implemented	Linked session/analytics data can remain
Formal retention policy in DB	Not implemented	Patient/session data can remain indefinitely
MongoDB Atlas controls (region, encryption, backup access)	Needs confirmation	Atlas is external to our Terraform; must be verified operationally

Database verdict: **Sensitive data is stored; lifecycle controls for GDPR are incomplete.**

3.4 Servers / infrastructure (AWS)

Item	Status	Notes
HTTPS	Present	Traffic encryption expected in prod/UAT
Secrets management	Present	AWS Secrets Manager / SSM
S3 music encryption at rest	Present	SSE-AES256
Monitoring / logs	Partial	CloudWatch logs and alarms exist
Hosting region	Gap for EU	**AWS `ap-south-1` (Mumbai, India)**
EU data residency	Not met	EU personal/health data outside EU needs transfer safeguards
Subprocessor documentation (AWS, MongoDB Atlas, email)	Not documented in product repos	Needed for GDPR transparency

Servers verdict: **Security hygiene is reasonable; **EU location / transfer** is not compliant as-is.**

4. Overall compliance status

Area	EU GDPR ready?
Frontend	No
Backend	No
Database	No / Partial
Servers (security controls)	Partial
Servers (EU data location)	No
Overall product	**Not EU GDPR compliant**

5. Gaps that must be closed before claiming EU compliance

Must-have (P0)

1. **Privacy Policy** and clear in-product notice
2. **Legal basis / consent** for processing health-related data (with legal review)
3. **Data Processing Agreement (DPA)** with hospitals / institutions
4. **Erase capability** — delete patient and all linked session/analytics data
5. **Export capability** — provide patient/user data on request
6. **Retention policy** — define and enforce how long session/HRV data is kept
7. **EU hosting / transfer plan** — host EU data in EU region, **or** put proper transfer contracts in place if India hosting continues
8. Document **subprocessors** (AWS, MongoDB Atlas, email provider, etc.)

Should-have (P1)

9. DPIA (Data Protection Impact Assessment) for HRV/health processing
10. Record of processing activities (RoPA)
11. Process/SLA for data-subject requests (access, erase, export)
12. Confirm Atlas encryption, backup access, and region settings in writing

6. What is already in good shape

- Role-based access for patient/admin operations
- HTTPS and CORS credentials support in production setup
- Secrets not hard-coded (Secrets Manager pattern)
- S3 encryption for music assets
- Some log retention (email logs TTL; CloudWatch retention configurable)
- API hardening (Helmet, validation, throttling on auth-related paths)

These are necessary security foundations, but **they alone do not equal GDPR compliance**.

7. Recommendation

Recommendation	Detail
Do not claim EU GDPR compliance yet	**Product is not ready**
Treat EU as a compliance project	**Legal + Engineering + DevOps jointly**
Prioritize rights + notices + data location	**Highest risk gaps for EU customers**
Get legal review	**Especially health data + India hosting**

8. One-paragraph summary

> Core security controls exist, but the product stores patient and health (HRV) data without GDPR essentials: privacy notice, consent, erase/export rights, retention rules, and EU-appropriate data location. Infrastructure currently runs in India (`ap-south-1`). **Skitii is not EU GDPR compliant today.**.

Note: This document is an engineering review of the current Skitii codebase and infrastructure configuration. It is not a formal legal opinion. Legal counsel should validate before any external GDPR compliance claims.